

The NIST and SANS Incident Response Frameworks

An incident response framework provides organizations with the direction and structure needed for security and cybersecurity incident prevention and mitigation. Out of the need for a standardized incident response framework, two organizations emerged as leaders with response frameworks that are now widely in use. In this reading, you'll explore and compare the National Institute of Standards and Technology (NIST) incident response framework to the SysAdmin, Audit, Network, and Security (SAN) incident response framework.

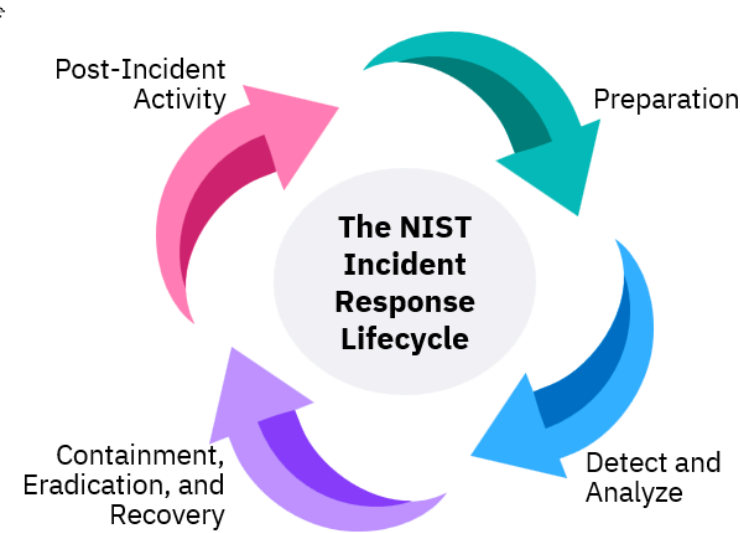
After completing this reading, you will be able to:

- Explain the NIST Incident Response Framework steps.
- Describe the SAN incident response framework steps.
- Summarize the differences between the two incident response frameworks.

Let's begin by learning about the NIST incident response framework.

NIST Incident Response Framework

The NIST Incident Response Framework provides a structured approach to managing cybersecurity incidents using well-defined steps. This framework outlines processes for preparing for incidents, detecting and analyzing threats, containing breaches, eradicating harmful elements, recovering systems, and conducting post-incident reviews to improve overall response strategies.



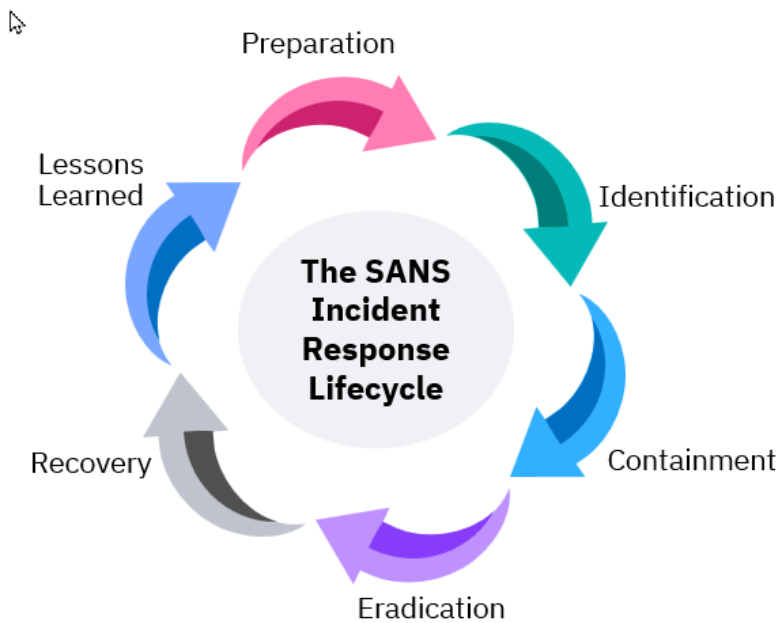
NIST Incident Response Lifecycle Steps	Goals	Actions
Preparation	• Establish and maintain an incident response capability to ensure readiness for incidents.	• Develop incident response policies • Train incident response teams • Conduct risk assessments and audits • Develop communication plans
Detection and Analysis	• Identify and confirm incidents through careful monitoring and assessment of security alerts.	• Monitor logs and alerts from security tools • Perform threat intelligence analysis • Verify alerts to minimize false positives • Conduct initial triage of incidents
Containment, Eradication, and Recovery	• Implement strategies to limit the impact of an incident and prevent further damage • Remove the cause of the incident and related vulnerabilities from the environment • Restore affected systems to operational status	• Isolate the affected systems • Secure backups and evidence • Identify and eliminate malware or threats • Apply patches and updates to remove vulnerabilities • Document eradication actions for future reference • Restore from backups as necessary • Monitor systems for signs of weaknesses or residual threats

Post-Incident Activity	Analyze responses to improve future incident handling and identify lessons learned.	- Gather evidence and document actions taken - Conduct root cause analysis - Review response effectiveness to refine policies and procedures - Determine if law enforcement involvement is necessary
------------------------	---	--

Resource: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf> (When you select this link, right-click and select the option to open this document in a new window.)

The SANS Incident Response Framework

The SANS Incident Response (IR) Framework is a structured approach that guides organizations through the critical stages of incident response, from preparation and detection to containment, eradication, and recovery. This framework emphasizes proactive measures and a systematic response to effectively manage and mitigate the impact of cybersecurity incidents.



SANS Incident Response Lifecycle Steps	Goals	Actions
Preparation	- Establish organization-wide security policies - Conduct risk assessments - Define security risks.	- Develop and implement security policies - Assess risks and vulnerabilities - Establish Computer Security Incident Response Team (CSIRT) roles and responsibilities
Identification	Monitor systems for unusual behavior and indicators of compromise.	- Continuously monitor network activity - Investigate alerts for potential incidents - Document findings and escalate as necessary
Containment	Take decisive, short-term actions to isolate potential threats and protect the network.	- Implement isolation tactics - Protect segregated systems - Develop a recovery plan for impacted systems
Eradication	Ensure complete removal of malware and vulnerabilities from affected systems.	- Identify and eliminate all threats - Perform root cause analysis - Apply patches and enhance security methods
Recovery	- Bring affected systems back online - Verify that the affected systems are operating correctly	- Restore systems from backups - Monitor systems for irregularities - Verify system integrity and effectiveness post-recovery
Lessons Learned	- Create a retrospective report detailing the incident within two weeks - Document the entire occurrence and identify opportunities for improving operational security	- Compile a comprehensive incident response report - Conduct a thorough analysis of response effectiveness - Identify and recommend security enhancements

Source: <https://www.lumifycyber.com/blog/the-sans-incident-response-framework/>

Now, let's compare the NIST and SANS incident response frameworks.

NIST and SANS Incident Response Frameworks compared

The following table provides the closest possible one-to-one comparison of these two frameworks.

The NIST framework	The SANS framework	Comparison
• Preparation	• Preparation	Minor wording differences. The NIST plan calls out training for the team.
• Detect and Analyze	• Identification	Although these stages are named differently and the tasks are worded differently, the tasks are essentially the same.
• Containment, Eradication, and Recovery	• Containment	The SANS incident response framework lists these tasks more granularly than the NIST incident response framework.
	• Eradication	
	• Recovery	
• Post-Incident Activity	• Lessons Learned	Although both frameworks are post-incident reviews, only the SANS framework specifies a two-week post-incident meeting.

Conclusion

Based on these comparisons, these two major incident response frameworks apply a similar approach to incident response management. Implementing either framework can benefit an organization.

Learn more

Explore both frameworks in more detail at the following links:

- [The National Institute of Standards and Technology \(NIST\) incident response framework](#)
- [The SysAdmin, Audit, Network, and Security \(SAN\) incident response framework](#)

Author(s)

[Patsy Kravitz](#)

